

Sentinel v1.0 Product Requirements Document (PRD)

Part 1 — Sections 1–7

1. Purpose

Sentinel is a self-hosted Endpoint Detection and Response (EDR) platform designed to help organizations detect, investigate, and understand security threats across Windows endpoints.

Sentinel provides:

- Endpoint telemetry collection
- Threat detection
- Incident correlation
- Attack graph visualization
- Threat hunting
- Security reporting

Sentinel focuses on visibility, detection, and investigation rather than automated response.

2. Product Vision

Provide organizations with a modern security platform that enables security teams to:

- Detect malicious activity
- Investigate attacks quickly
- Understand attack progression
- Correlate related security events
- Visualize attack paths
- Hunt for threats proactively

Sentinel aims to provide enterprise-grade visibility while remaining fully self-hosted and under customer control.

3. Product Goals

Goal 1

Detect common Windows attack techniques in near real time.

Target

High Severity Alerts Visible $\leq$ 5 Seconds

from event occurrence to dashboard visibility.

Goal 2

Provide complete attack visibility.

Security analysts should be able to identify:

- Initial Access
- Execution
- Persistence
- Lateral Movement
- Credential Access

through a single investigation workflow.

Goal 3

Reduce investigation time.

Target

Alert

↓

Incident

↓

Root Cause

within minutes rather than hours.

Goal 4

Provide attack path visualization.

Analysts should understand:

User

↓

Endpoint

↓

Process

↓

Domain/IP

↓

Alert

↓

Incident

through attack graphs.

Goal 5

Support proactive threat hunting.

Analysts should be able to search historical telemetry across:

- Users
 - Endpoints
 - Processes
 - Files
 - Domains
 - IP Addresses
 - Alerts
 - Incidents
-

4. Product Scope

Included in v1.0

Endpoint Monitoring

- Windows Endpoint Telemetry Collection
 - ETW Integration
 - AMSI Integration
 - Sysmon Integration
 - Windows Event Log Integration
-

Threat Detection

- Behavioral Rules
- Sigma Rules
- IOC Matching

- ML-Based Anomaly Detection
 - Alert Deduplication
-

Incident Management

- Alert Generation
 - Alert Grouping
 - Incident Creation
 - Incident Tracking
 - Investigation Workflow
-

Attack Graph Visualization

- Entity Relationships
 - Attack Path Visualization
 - Interactive Graph Exploration
 - Neo4j-Powered Attack Graphs
-

Threat Hunting

- Historical Search
 - Entity Pivoting
 - Investigation Workflows
-

Reporting

- Incident Reports
 - Security Reports
 - Executive Summaries
 - CSV Export
 - JSON Export
-

User Management

- Authentication
- RBAC

- User Lifecycle Management
-

Platform Administration

- Organization Management
 - License Management
 - Platform Configuration
-

5. Out of Scope (v1.0)

Automated Response

Examples:

- Endpoint Isolation
 - Process Termination
 - Automated Remediation
-

SOAR

Examples:

- Playbooks
 - Automated Workflows
 - Automated Containment
-

Zero Trust

Examples:

- Trust Scoring
 - Dynamic Access Decisions
-

UEBA

Examples:

- User Risk Scores
 - Insider Threat Scoring
-

Cross Platform Agents

Deferred:

- Linux
 - macOS
-

Kernel Drivers

Sentinel v1.0 uses:

- ETW
- AMSI
- Sysmon
- Event Logs

No custom kernel drivers will be developed.

6. Target Users

Owner

The Owner is the Sentinel platform owner.

Responsibilities

- Platform Management
- Organization Management
- Initial Administrator Assignment
- License Management
- Platform Maintenance
- System Recovery

Permissions

Full Platform Access

The Owner has visibility across all organizations.

The Owner is not responsible for day-to-day investigations.

Security Administrator

Responsibilities

- Deploy Sentinel
- Manage Users

- Manage Policies
- Manage IOC Datasets
- Manage Organization Configuration

Permissions

Organization-Level Administrative Access

Security Administrators can only access resources within their organization.

Security Analyst

Responsibilities

- Monitor Alerts
- Investigate Incidents
- Use Threat Hunting
- Generate Reports
- Analyze Attack Graphs

Permissions

Investigation Access

Security Analysts cannot manage users, policies, or organization settings.

7. Success Criteria

Detection

At least:

15 Native Behavioral Rules

operational.

At least:

25–40 Sigma Rules

operational.

IOC Matching operational.

ML Anomaly Detection operational.

Endpoint Visibility

Endpoint telemetry collected successfully.

High Severity Alerts visible within:

5 Seconds

Standard telemetry visible within:

10 Seconds

Investigation

Incident Correlation operational.

Attack Graphs operational.

Threat Hunting operational.

Performance

Agent CPU Usage:

< 3%

Agent Memory Usage:

< 200 MB

Dashboard Load Time:

< 3 Seconds

Scalability

Sentinel shall support:

100 Concurrent Endpoints

without architectural redesign.

Sentinel v1.0 Product Requirements Document (PRD)

Part 2 — Sections 8–13

8. Sentinel Agent

Purpose

The Sentinel Agent is installed on every protected Windows endpoint.

The agent is responsible for:

- Collecting telemetry
 - Normalizing telemetry into SUES
 - Buffering telemetry locally
 - Sending telemetry securely to Sentinel
 - Sending health heartbeats
 - Applying collection policies
-

Platform

Supported Platform:

Windows Only

Installation

Installation Method:

MSI Package

Supported Deployment Methods:

- Manual Installation
 - Group Policy (GPO)
 - SCCM
 - Microsoft Intune
-

Execution Mode

The agent runs as:

Windows Service

Startup Type:

Automatic

The agent starts whenever the endpoint boots.

Telemetry Collection Responsibilities

The agent shall collect:

- ETW Events
 - AMSI Events
 - Sysmon Events
 - Windows Event Logs
-

Event Normalization

All collected telemetry shall be converted into:

SUES

(Sentinel Unified Event Schema)

before transmission.

Local Event Buffer

The agent shall maintain a local event buffer.

Purpose:

- Network Outages
 - Backend Failures
 - Temporary Connectivity Issues
-

Buffer Eviction Policy

Maximum Buffer Size:

1 GB

When utilization exceeds:

90%

the agent shall:

1. Retain security-relevant telemetry
2. Evict oldest low-priority telemetry first

Telemetry collection shall continue.

Telemetry Priority Levels

High Priority

Examples:

- Detection Alerts
 - Authentication Events
 - AMSI Events
 - Process Creation Events
 - Security Events
-

Medium Priority

Examples:

- Network Events
 - Registry Events
 - File Events
-

Low Priority

Examples:

- Informational System Events
 - Diagnostic Events
 - Performance Events
-

When buffer utilization exceeds:

90%

the agent shall evict telemetry in the following order:

Low Priority

↓

Medium Priority

↓

High Priority

High Priority telemetry shall be retained whenever possible.

Delivery Retry Policy

Failed event deliveries shall be retried automatically.

Retry Interval:

30 Seconds

Retry Attempts:

Unlimited

while buffer space remains available.

Failures shall be logged locally.

Secure Communication

Agent communication shall use:

HTTPS

TLS 1.3

Certificate Pinning

Certificate Validation Failure

If certificate pinning validation fails:

- Telemetry transmission shall be blocked.
- Events shall be logged locally.
- Agent health shall be marked as Degraded.
- Local telemetry buffering shall continue.

This behavior protects against potential MITM attacks.

Certificate Compromise Recovery

If a pinned certificate becomes compromised:

v1.0 recovery requires:

- New certificate generation
- Agent redeployment
- Manual trust replacement

Automatic certificate rotation is deferred to v1.1.

Health Monitoring

Agent health messages shall include:

- Endpoint ID
 - Agent Version
 - Policy Version
 - Status
 - Timestamp
-

Heartbeat Policy

Heartbeat Interval:

60 Seconds

Healthy

Heartbeat received normally.

Degraded

Miss:

3 Consecutive Heartbeats

Offline

Miss:

10 Consecutive Heartbeats

9. Telemetry Collection

Purpose

Provide endpoint visibility required for detection and investigation.

Telemetry Sources

ETW

Collect:

- Process Activity
 - Network Activity
 - Security Events
-

AMSI

Collect:

- Script Content
 - Script Execution Events
 - PowerShell Activity
-

Sysmon

Collect:

- Process Creation
 - Network Connections
 - Registry Activity
 - File Activity
-

Windows Event Logs

Collect:

- Authentication Events
 - Security Events
 - System Events
-

Policy-Based Collection

Telemetry collection shall be configurable.

Examples:

Collect Process Events

Collect Network Events

Collect Registry Events

Collect File Events

Telemetry Retention

Default Retention:

90 Days

Configurable Options:

- 30 Days
 - 90 Days
 - 180 Days
 - 365 Days
-

10. Sentinel Unified Event Schema (SUES)

Purpose

Provide a common internal schema for all telemetry.

All telemetry must be normalized into SUES before:

- Storage
 - Detection
 - Threat Hunting
 - Graph Processing
-

Core Fields

Every SUES event shall contain:

Field	Description
eventId	Unique Event ID
schemaVersion	Schema Version
timestamp	Event Timestamp
endpointId	Endpoint Identifier
organizationId	Organization Identifier
eventType	Event Type

Field	Description
source	Telemetry Source
userId	Associated User
severity	Event Severity

Valid Severity Values

Informational

Low

Medium

High

Critical

Schema Versioning

Every SUES event shall contain:

```
{  
  "schemaVersion": "1.0"  
}
```

Future schema versions shall maintain backward compatibility whenever possible.

Supported Event Types

Process Event

Examples:

- Process Created
 - Process Terminated
-

Network Event

Examples:

- Connection Opened
 - Connection Closed
-

Authentication Event

Examples:

- Login Success
 - Login Failure
-

Registry Event

Examples:

- Registry Created
 - Registry Modified
 - Registry Deleted
-

File Event

Examples:

- File Created
 - File Accessed
 - File Modified
 - File Deleted
 - File Loaded
-

Script Event

Examples:

- PowerShell
 - VBScript
 - JavaScript
-

Design Objectives

SUES shall provide:

- Consistent Event Structure
- Vendor-Neutral Processing
- Simplified Detection Logic
- Simplified Threat Hunting

- Simplified Graph Generation
-

Data Consumers

SUES events shall be consumed by:

- Detection Engine
 - ML Anomaly Engine
 - Incident Correlation Engine
 - Attack Graph Engine
 - Threat Hunting Engine
 - Reporting Engine
-

11. Detection Engine

Purpose

Identify suspicious or malicious activity.

Architecture

Detection Engine

└─ Behavioral Rules

└─ Sigma Rules

└─ IOC Matching

└─ ML Anomaly Engine

Behavioral Rules

Native Sentinel detections.

Examples:

- Office Spawning PowerShell
- Encoded PowerShell
- Certutil Abuse
- Rundll32 Abuse
- MSHTA Abuse
- Credential Dumping

Target:

15 Native Rules

Sigma Rules

Community-driven detections.

Target:

25–40 Sigma Rules

Sigma Processing

Sigma Rule

↓

SUES Mapping

↓

Detection Logic

↓

Execution

IOC Matching

Supported Indicator Types:

- IP Address
 - Domain
 - URL
 - File Hash
-

IOC Sources

v1.0:

Manual Upload

Supported Formats:

- CSV
 - JSON
-

IOC Expiration

Default Expiration:

180 Days

Expired indicators shall be ignored automatically.

IOC Expiration Notifications

Security Administrators shall receive notifications when:

- IOC expiration is approaching
- IOC expiration has occurred

Default Warning Period:

30 Days

before expiration.

Alert Deduplication

Duplicate alerts shall be suppressed.

Criteria:

- Same Rule
- Same Endpoint
- Same User
- Within 60 Seconds

Instead of generating multiple alerts:

Occurrence Counter++

shall be updated.

The occurrence count shall be visible to analysts within the alert details page.

12. ML Anomaly Engine

Purpose

Identify suspicious activity not detected by traditional rules.

Role

ML acts as:

Standalone Low/Medium Detector

+

Secondary Confidence Signal

Detection Model

Initial Model:

Isolation Forest

Inputs

Examples:

- Process Frequency
 - Parent Process Frequency
 - Execution Time
 - Network Activity
 - Domain Diversity
 - Login Activity
-

Baseline Requirements

New endpoints enter a learning period.

Default Learning Period:

7 Days

During learning:

- Anomaly Scores Generated
 - Informational Alerts Only
-

Learning Period Alert Behavior

Informational alerts:

- Are visible in the Alerts page
- Do not participate in incident correlation
- Do not affect incident severity
- Exist solely for model visibility and tuning

Endpoint Reimaging Handling

If an endpoint is reimaged:

- A new Endpoint ID shall be generated
- Previous ML baselines shall not be reused
- A new learning period shall begin automatically

Alert Generation

ML may independently generate:

- Low Alerts
- Medium Alerts

ML shall not independently generate:

- High Alerts
- Critical Alerts

High and Critical alerts require confirmation from:

- Behavioral Rules
- Sigma Rules
- IOC Matching

Output

ML produces:

Anomaly Score

used for:

- Alert Prioritization
- Confidence Enhancement
- Unknown Threat Detection

13. Incident Correlation

Purpose

Group related alerts into investigations.

Correlation Factors

Alerts may be grouped using:

- Endpoint
- User
- Process
- Time Window
- Shared Indicators

Correlation Window

Default:

15 Minutes

Post-Window Handling

Alerts arriving after the correlation window:

Create New Incident

Analysts may manually merge incidents.

Incident Alert Capacity

An incident may contain an unlimited number of alerts.

To maintain usability:

100 Alerts Per Page

shall be used for pagination in the Incident Details page.

Incident Merge Rules

Severity

Highest severity wins.

Status

Most active status wins.

Priority Order:

Investigating



Open



Resolved



Closed

Assignee

Primary incident assignee is retained.

Incident Assignment

Incidents shall be unassigned by default.

Security Analysts may self-assign incidents.

Security Administrators may assign incidents to analysts within their organization.

Only one primary assignee may exist at a time.

All alerts, notes, evidence, entities, and timelines shall be preserved.

Incident Statuses

- Open
 - Investigating
 - Resolved
 - Closed
-

Incident Severities

- Low
 - Medium
 - High
 - Critical
-

Escalation Logic

Credential Access

or

Defense Evasion

↓

High Severity

minimum.

Multiple High alerts may escalate to:

Critical

Sentinel v1.0 Product Requirements Document (PRD)

Part 3 — Sections 14–18

14. Attack Graphs

Purpose

Provide visual understanding of attack progression.

Attack Graphs help analysts understand how an attack moved through:

- Users
 - Endpoints
 - Processes
 - Files
 - Domains
 - IP Addresses
 - Alerts
 - Incidents
-

Technology

Neo4j Community Edition

Supported Nodes

- User

- Endpoint
 - Process
 - File
 - Domain
 - IP Address
 - Alert
 - Incident
-

Supported Relationships

User Authentication

User

LOGGED_INTO

Endpoint

Example:

Alice

LOGGED_INTO

PC-001

Process Execution

Endpoint

EXECUTED

Process

Example:

PC-001

EXECUTED

powershell.exe

Process Spawning

Process

CREATED

Process

Example:

WINWORD.EXE

CREATED

powershell.exe

File Access

Process

ACCESSED

File

Example:

powershell.exe

ACCESSED

salary.xlsx

File Creation

Process

CREATED

File

Example:

powershell.exe

CREATED

payload.exe

File Modification

Process

MODIFIED

File

Example:

ransomware.exe

MODIFIED

document.docx

File Deletion

Process

DELETED

File

Example:

malware.exe

DELETED

backup.zip

DLL / File Loading

Process

LOADED

File

Example:

rundll32.exe

LOADED

malicious.dll

Network Communication

Process

CONNECTED_TO

Domain

Example:

powershell.exe

CONNECTED_TO

evil.com

DNS Resolution

Domain

RESOLVES_TO

IP Address

Example:

evil.com

RESOLVES_TO

185.44.22.11

Alert Attribution

Alert

TRIGGERED_BY

Entity

Supported Entity Types:

- Process
- File
- Domain
- IP Address

Examples:

Encoded PowerShell Alert

TRIGGERED_BY

powershell.exe

Known Malware Alert

TRIGGERED_BY

payload.exe

Malicious Domain Alert

TRIGGERED_BY

evil.com

Threat Intelligence Alert

TRIGGERED_BY

185.44.22.11

Endpoint Attribution

Alert

AFFECTS

Endpoint

Example:

Credential Dumping Alert

AFFECTS

PC-001

Incident Membership

Alert

PART_OF

Incident

Example:

PowerShell Alert

PART_OF

Incident-123

User Attribution

Incident

INVOLVES

User

Example:

Incident-123

INVOLVES

Alice

Capabilities

Relationship Visualization

Display relationships between:

- Users
- Endpoints
- Processes

- Files
- Domains
- IP Addresses
- Alerts
- Incidents

Investigation Support

Allow analysts to:

- Expand Nodes
- Explore Relationships
- Inspect Entity Metadata
- Trace Attack Paths
- Pivot Between Entities

Incident Context

Provide complete attack-chain visibility.

Example:

User

↓

Endpoint

↓

WINWORD.EXE

↓

powershell.exe

↓

payload.exe

↓

evil.com

↓

185.44.22.11

↓

Alert

↓

Incident

Malware Drop Scenario

WINWORD.EXE

↓ CREATED

powershell.exe

↓ CREATED

payload.exe

↓ CONNECTED_TO

evil.com

↓ RESOLVES_TO

185.44.22.11

Ransomware Scenario

User

↓

Endpoint

↓

ransomware.exe

↓ MODIFIED

500 Files

↓

Alert

↓

Incident

Credential Theft Scenario

User

↓

Endpoint

↓

powershell.exe

↓ CREATED

mimikatz.exe

↓

Credential Dumping Alert

↓

Incident

Investigation Objectives

Attack Graphs shall enable analysts to answer:

- How did the attack start?
 - Which user was involved?
 - Which endpoint was affected?
 - Which processes executed?
 - Which files were created, modified, accessed, loaded, or deleted?
 - Which domains and IP addresses were contacted?
 - Which alerts contributed to the incident?
 - What was the complete attack path?
-

Design Objectives

Attack Graphs shall provide:

- Visual Attack Reconstruction
 - Entity Relationship Exploration
 - Investigation Acceleration
 - Threat Context Enrichment
 - Root Cause Analysis Support
-

15. Threat Hunting

Purpose

Enable analysts to proactively search historical telemetry for suspicious activity.

Threat Hunting allows analysts to investigate:

- Known Threats
- Emerging Threats
- Suspicious Behavior
- Incident-Related Activity

without waiting for alerts.

Supported Search Targets

Users

Examples:

- Alice
 - Bob
 - Administrator
-

Endpoints

Examples:

- PC-001
 - LAPTOP-123
 - SERVER-01
-

Processes

Examples:

- powershell.exe
 - cmd.exe
 - rundll32.exe
-

Files

Examples:

- invoice.docx
- payload.exe

- malicious.dll
-

Domains

Examples:

- google.com
 - evil.com
-

IP Addresses

Examples:

- 8.8.8.8
 - 185.44.22.11
-

Alerts

Search by:

- Alert Name
 - Severity
 - Detection Source
 - MITRE Technique
-

Incidents

Search by:

- Incident ID
 - Status
 - Severity
 - Assignee
-

Threat Hunting Capabilities

Historical Search

Search historical telemetry across configured retention periods.

Entity Pivoting

Analysts shall be able to pivot between related entities.

User



Endpoint



Process



File



Domain/IP



Alert



Incident

without manual searching.

Filtered Search

Support:

- Time Range
- Endpoint
- User
- Process
- File
- Domain
- IP Address
- Severity

Search Results

Search results shall support:

- Sorting
- Filtering

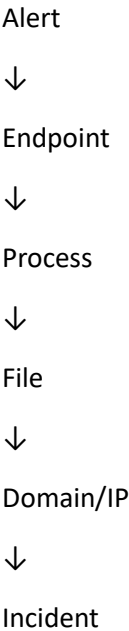
- Pagination
- Entity Pivoting

Threat Hunting Results Table

Column	Description
Timestamp	Event Time
Entity Type	User, Endpoint, Process, File, Domain, IP, Alert, Incident
Entity Name	Entity Identifier
Endpoint	Associated Endpoint
User	Associated User
Severity	Event Severity
Related Alert Count	Linked Alerts

Investigation Workflows

Workflow 1 — Alert-Based Investigation



Workflow 2 — User-Based Investigation



Endpoints



Processes



Alerts



Incidents

Workflow 3 — IOC-Based Investigation

Domain / IP / File Hash



File (if applicable)



Affected Endpoints



Processes



Alerts



Incidents

Workflow 4 — File Investigation

File



Creating Process



Parent Process



Endpoint



User



Related Alerts

Search Performance Requirements

Normal hunting queries shall return results within:

5 Seconds

under supported deployment scale.

Access Control

Owner

May search across:

All Organizations

Security Administrator

May search within:

Their Organization

Security Analyst

May search within:

Their Organization

Deferred Features

Deferred to v1.1:

- Saved Hunts
 - Scheduled Hunts
 - Advanced Query Language
 - Boolean Operators
 - Query Templates
-

Design Objectives

Threat Hunting shall provide:

- Fast Investigation Workflows
 - Historical Visibility
 - Efficient Entity Pivoting
 - Minimal Navigation Depth
 - Context-Rich Investigations
-

16. Reporting

Purpose

Provide security reporting capabilities for analysts, administrators, management, and platform owners.

Reporting shall enable:

- Incident Documentation
 - Security Operations Visibility
 - Trend Analysis
 - Compliance Support
 - Executive Communication
-

Report Types

Incident Report

Contains:

- Incident Summary
 - Incident Severity
 - Timeline
 - Related Alerts
 - Related Entities
 - Investigation Notes
 - Resolution Actions
 - Closure Details
-

Security Operations Report

Contains:

- Alert Statistics
 - Incident Statistics
 - Detection Statistics
 - Endpoint Statistics
 - Analyst Activity
 - Trend Analysis
-

Executive Summary Report

Contains:

- Security Overview
 - Critical Incidents
 - Incident Trends
 - Detection Trends
 - Risk Overview
 - Key Metrics
-

Supported Export Formats

v1.0

- CSV
- JSON

Deferred

- PDF Export (v1.1)
-

Report Filters

- Time Range
 - Severity
 - Endpoint
 - User
 - Incident Status
 - Detection Source
-

Report Generation

v1.0:

Manual Report Generation

Deferred:

Scheduled Report Generation (v1.1)

Report Access Control

Owner

All Reports

All Organizations

Security Administrator

All Reports

Within Organization

Security Analyst

Investigation Reports

Security Reports

Within Organization

Multi-Tenant Data Isolation

Enforced at:

- Authentication Layer
- Authorization Layer
- API Layer
- Database Query Layer

Organization data shall remain isolated according to assigned role permissions.

Performance Requirements

Reports shall be generated within:

30 Seconds

for normal deployment sizes.

Large reports may be generated asynchronously.

Audit Logging

Log:

- Report Generation
- Report Export
- Report Download

Fields:

- User
 - Role
 - Timestamp
 - Report Type
 - Export Format
-

Design Objectives

Reporting shall provide:

- Actionable Security Insights
 - Investigation Documentation
 - Management Visibility
 - Export Flexibility
 - Organization-Level Data Isolation
-

17. Authentication & RBAC

Purpose

Provide secure authentication and authorization.

Authentication Platform

Keycloak

Registration Model

Sentinel shall not provide:

- Public Registration
- Public Signup

All users are created by authorized administrators.

Roles

Owner

Platform-Level Role.

Responsibilities:

- Create Organizations
- Delete Organizations
- Assign First Security Administrator
- License Management
- System Maintenance
- Platform Recovery
- Global Configuration

Access:

- All Organizations
- All Users
- All Endpoints
- All Reports

Security Administrator

Organization-Level Role.

Responsibilities:

- Manage Users
- Manage Policies
- Manage IOC Datasets
- Manage Organization Settings

Security Analyst

Investigation-Level Role.

Responsibilities:

- Monitor Alerts
- Investigate Incidents
- Use Threat Hunting
- Generate Reports
- Analyze Attack Graphs

Cannot:

- Create Users
- Modify Policies
- Change Organization Settings

Session Management

Access Token:

15 Minutes

Refresh Token:

7 Days

Logout invalidates active sessions.

Account Lockout

Failed Login Threshold:

5 Attempts

Lockout Duration:

15 Minutes

Implemented through Keycloak.

Owner Recovery Procedure

If the Owner account becomes locked:

Recovery shall occur through direct Keycloak administrative access.

Security Administrators shall not have authority to recover Owner accounts.

Password Policy

Minimum Length:

12 Characters

Requirements:

- Uppercase Letter
 - Lowercase Letter
 - Number
 - Special Character
-

Password Reset

SMTP configuration is mandatory.

Reset links shall be delivered through email.

Multi-Tenant Access Control

Security Administrators and Security Analysts shall only access data belonging to their organization.

The Owner role shall bypass organization boundaries.

Access control shall be enforced at:

- Authentication Layer
 - Authorization Layer
 - API Layer
 - Database Query Layer
-

18. Dashboard & User Interface

Purpose

Provide centralized visibility and investigation capabilities.

Primary Navigation

Overview

Alerts

Incidents

Threat Hunting

Attack Graph

Endpoints

Reports

Users

Settings

Overview Dashboard

Displays:

Endpoint Metrics

- Total Endpoints
- Healthy Endpoints
- Degraded Endpoints
- Offline Endpoints

Alert Metrics

- Active Alerts
- Critical Alerts
- High Alerts

Incident Metrics

- Open Incidents
- Investigating Incidents
- Critical Incidents

Recent Activity

- Recent Alerts
 - Recent Incidents
-

Alerts Page

Capabilities:

- Search
- Filtering
- Sorting
- Pagination

Columns:

- Severity
 - Alert Name
 - Endpoint
 - User
 - Detection Source
 - MITRE Technique
 - Timestamp
 - Status
-

Incident Page

Displays:

- Incident Summary
 - Timeline
 - Evidence
 - Notes
 - Related Alerts
 - Related Entities
 - Attack Graph
-

Attack Graph Page

Powered By:

Neo4j + Cytoscape.js

Capabilities:

- Node Expansion
 - Relationship Exploration
 - Entity Inspection
 - Attack Path Visualization
-

Threat Hunting Page

Displays:

- Search Interface

- Filters
 - Results Table
 - Pivot Links
-

Endpoints Page

Displays:

- Endpoint Status
 - Agent Version
 - Policy Version
 - Last Heartbeat
-

Users Page

Displays:

- User Accounts
 - Assigned Roles
 - Account Status
-

Settings Page

Displays:

- Policy Management
 - IOC Management
 - Organization Settings
 - Platform Configuration
-

Settings Access Control

Platform Configuration

Owner Only

Examples:

- Licensing
- Global Platform Settings
- Certificate Management

- System Configuration

Organization Settings

Security Administrator

Examples:

- User Management
 - IOC Management
 - Policy Management
 - Organization Configuration
-

Frontend Requirements

Loading State

Use:

Skeleton Loaders

instead of spinner-only indicators.

Empty State

No Data Available

Error State

Unable To Load Data

with retry capability.

Security Requirements

Frontend shall not expose:

- Stack Traces
- Internal Errors
- Sensitive Configuration Data

Sentinel v1.0 Product Requirements Document (PRD)

Part 4 — Sections 19–23

19. Non-Functional Requirements

Purpose

Define performance, scalability, reliability, maintainability, and usability requirements.

Performance Requirements

Detection Latency

High Severity Alerts shall be visible in the dashboard within:

≤ 5 Seconds

from event occurrence.

Standard Telemetry shall be visible within:

≤ 10 Seconds

from event occurrence.

Dashboard Performance

Page Load Time:

< 3 Seconds

Threat Hunting Search Response

< 5 Seconds

for normal search workloads.

Agent Resource Usage

Normal operation is defined as:

- Telemetry collection enabled
- Detection processing enabled
- No active outage conditions
- No local buffer pressure above 90%

CPU Usage:

< 3%

during normal operation.

Memory Usage:

< 200 MB

during normal operation.

Maximum Local Buffer Size:

1 GB

Scalability Requirements

Sentinel shall support:

100 Concurrent Endpoints
without architectural redesign.

Future scaling shall be supported through:

- Horizontal API Scaling
 - PostgreSQL Optimization
 - Redis Scaling
 - Neo4j Scaling
-

Reliability Requirements

Sentinel shall continue operating during:

- Temporary Network Failures
- Endpoint Connectivity Issues
- Redis Restarts
- Neo4j Failures

where possible.

Graceful degradation shall be implemented.

Example:

Neo4j Failure

↓

Attack Graphs Unavailable

↓

Detection Continues

20. Operational Security & Reliability Requirements

Purpose

Define production security and operational requirements.

Input Validation

All API requests shall validate:

- Required Fields
- Data Types
- Length Constraints
- Format Constraints

Invalid requests shall be rejected.

Input Sanitization

User-generated content shall be sanitized.

Protection required against:

- Cross-Site Scripting (XSS)
- HTML Injection
- Script Injection

Applicable fields include:

- Notes
 - Comments
 - Organization Names
 - User Content
-

Cross-Origin Resource Sharing (CORS)

Production deployments shall use:

Approved Origin Allowlist

Wildcard origins shall not be used.

Rate Limiting

Authentication APIs

5 Requests / Minute
per user/IP.

Standard APIs

100 Requests / Minute
per authenticated user.

Administrative APIs

50 Requests / Minute
per administrator.

Owner APIs

100 Requests / Minute
per Owner account.

Owner operations may span multiple organizations and therefore use a separate limit.

Session Security

Access Token:

15 Minutes

Refresh Token:

7 Days

Sessions shall be invalidated upon logout.

Password Reset Security

Requirements:

- Single Use Tokens
- Secure Random Tokens
- Expiration Enforcement

Default Expiration:

15 Minutes

Logging Requirements

Sentinel shall log:

- Authentication Events
- Authorization Events
- Alert Generation
- Incident Creation
- Administrative Actions
- System Errors

Log Retention

Operational and audit logs shall be retained for:

180 Days

by default.

Configurable Options:

- 90 Days
- 180 Days
- 365 Days

Monitoring

Monitor:

- API Latency
- Error Rates
- Agent Heartbeats
- Database Health
- Resource Utilization

Operational Alerting

Generate operational alerts for:

- Backend Failures
- Database Failures

- Agent Communication Failures
 - Detection Engine Failures
-

Secrets Management

Sensitive credentials shall never be stored in source code.

Examples:

- Database Credentials
- API Keys
- JWT Secrets
- Service Tokens

Secrets shall be managed using:

Environment Variables

or equivalent secure configuration.

Dependency Security

Dependencies shall be scanned regularly for known vulnerabilities.

Security updates shall be applied according to risk severity.

Backup & Recovery

Backups shall be performed regularly.

Requirements:

- Backup Validation
 - Restoration Testing
 - Documented Recovery Procedures
-

Deployment Safety

Deployments shall support:

Rollback To Previous Stable Version

without requiring full platform restoration.

Certificate Strategy

Sentinel shall use:

TLS 1.3

for all communications.

Agent certificate pinning shall be implemented.

v1.0 Certificate Strategy

- Self-Signed Certificate
 - Embedded During Agent Installation
 - 10-Year Validity
-

Deferred:

Automatic Certificate Rotation (v1.1)

21. Deployment Model

Deployment Type

Sentinel v1.0 is:

Self-Hosted

High-Level Architecture

Windows Endpoints



Sentinel Agents



HTTPS



ASP.NET Core API



Redis Streams



Detection Engine



PostgreSQL



Neo4j



React Dashboard

Backend Components

ASP.NET Core API

Responsibilities:

- Authentication
- Event Ingestion
- Detection Processing
- Dashboard APIs

PostgreSQL

Stores:

- Telemetry
- Alerts
- Incidents
- Users
- Configuration

Redis Streams

Responsibilities:

- Event Pipeline
- Event Buffering
- Detection Queue

Neo4j

Stores:

- Entity Relationships
 - Attack Graph Data
-

Keycloak

Provides:

- Authentication
 - Identity Management
 - RBAC Integration
-

Agent Deployment

Supported Methods:

- Manual Installation
 - Group Policy (GPO)
 - SCCM
 - Microsoft Intune
-

22. Deferred Features

The following features are intentionally excluded from Sentinel v1.0.

SOAR

Deferred:

v1.1+

Examples:

- Endpoint Isolation
 - Process Termination
 - Automated Containment
 - Automated Remediation
-

Deception Technology

Deferred:

v1.1+

Examples:

- Honey Files
 - Honey Credentials
 - Canary Tokens
-

Advanced Threat Hunting

Deferred:

v1.1+

Examples:

- Saved Hunts
 - Scheduled Hunts
 - Query Language
 - Advanced Search Operators
-

Advanced Machine Learning

Deferred:

v1.1+

Examples:

- XGBoost Confidence Scoring
 - UEBA
 - Risk Scoring
 - Behavioral Profiling
-

Advanced Graph Analytics

Deferred:

v1.1+

Examples:

- Blast Radius Analysis
 - Path Scoring
 - Automated Attack Chain Discovery
-

Cross Platform Agents

Deferred:

v1.2+

Platforms:

- Linux
 - macOS
-

Automatic Agent Updates

Deferred:

v1.1+

v1.0 uses:

Manual MSI Upgrade

Automatic Threat Intelligence Feeds

Deferred:

v1.1+

v1.0 uses:

Manual IOC Upload

Automatic Certificate Rotation

Deferred:

v1.1+

23. Release Definition

Sentinel v1.0 shall be considered complete when all requirements below are satisfied.

Detection

- ✓ Behavioral Rules Operational
- ✓ Sigma Rules Operational
- ✓ IOC Matching Operational
- ✓ ML Anomaly Engine Operational

✓ Alert Deduplication Operational

Visibility

✓ Endpoint Telemetry Collected Successfully

✓ Telemetry Normalized Into SUES

✓ Dashboard Displays Telemetry Correctly

✓ Heartbeat Monitoring Operational

Investigation

✓ Incident Correlation Operational

✓ Attack Graph Generation Operational

✓ Threat Hunting Operational

Platform

✓ Authentication Operational

✓ RBAC Operational

✓ User Management Operational

✓ Reporting Operational

Performance

✓ Detection Latency Requirements Met

✓ Dashboard Performance Requirements Met

✓ Agent Resource Targets Met

Security

✓ Security Controls Verified

✓ Monitoring Operational

✓ Alerting Operational

✓ Logging Operational

✓ Backup Recovery Tested

- ✓ Rollback Procedures Tested
 - ✓ Certificate Pinning Operational
-

Documentation

- ✓ PRD Approved
 - ✓ TRD Approved
 - ✓ AFD Approved
 - ✓ UI/UX Brief Approved
 - ✓ Backend Schema Approved
 - ✓ Implementation Plan Approved
-

End of Sentinel v1.0 PRD

Final v1.0 Architecture

Agent

↓

SUES

↓

Detection Engine

├─ Behavioral Rules

├─ Sigma Rules

├─ IOC Matching

└─ ML Anomaly Engine

↓

Alert Generation

↓

Incident Correlation

↓

Attack Graph Generation

↓

Threat Hunting



Dashboard Investigation

Roles

Owner



Security Administrator



Security Analyst